

**НЕКОММЕРЧЕСКОЕ АКЦИОНЕРНОЕ ОБЩЕСТВО
«КАЗАХСКИЙ НАЦИОНАЛЬНЫЙ ПЕДАГОГИЧЕСКИЙ
УНИВЕРСИТЕТ ИМЕНИ АБАЯ»**



УТВЕРЖДЕНО

Решением Правления

НАО «Казахский национальный
педагогический университет
имени Абая»

от «15» _____ 2025 года

Протокол № _____

Председатель Правления _____ Ректор
Тілеп Б.А.



**План обработки угроз и рисков информационной безопасности
Некоммерческого акционерного общества «Казахский национальный
педагогический университет имени Абая»**



Оглавление

1 Общие положения.....	3
2 Нормативная основа	3
3 Методология обработки угроз и рисков.....	3
4 План обработки рисков.....	4
5 Мониторинг выполнения плана.....	5
6 Ответственность.	5
Лист согласования.....	7

1 Общие положения

1.1 Настоящий План обработки угроз и рисков информационной безопасности Некоммерческого акционерного общества «Казахский национальный педагогический университет имени Абая» (далее — Университета) разработаны в соответствии с требованиями законодательства и стандартов Республики Казахстан в области информационной безопасности.

1.2 Целью настоящего документа является создание процесса обеспечения надежной защиты информационных ресурсов и систем университета от потенциальных угроз, минимизации рисков нарушения конфиденциальности, целостности и доступности информации.

1.3 План определяет основные подходы, процедуры и меры по выявлению, анализу, обработке и контролю угроз и рисков, связанных с информационной безопасностью, а также регламентирует действия ответственных лиц.

1. В настоящих Правилах используются следующие основные термины и сокращения:

ИТ-инфраструктура — совокупность информационных технологий, аппаратных и программных средств, сетевых ресурсов и процессов, которые обеспечивают функционирование и поддержку информационных систем университета;

ИБ — Информационная безопасность;

ПО — программное обеспечение;

ОС — Операционная система;

Администратор - сотрудник, отвечающий за настройку, оптимизацию и обслуживание ИТ-инфраструктуры университета;

Пользователь — Пользователь информационной системы;

2 Нормативная основа

Настоящий документ разработан в соответствии со следующими нормативно-правовыми актами и документами:

- Постановление Правительства Республики Казахстан от 20.12.2016г. №832 «Об утверждении единых требований в области информационно-коммуникационных технологий и обеспечения информационной безопасности»;

3 Методология обработки угроз и рисков

3.1 Обработка угроз и рисков информационной безопасности базируется на следующих принципах:

- Приоритетность — обеспечение защиты наиболее значимых активов, которые критически важны для функционирования университета.

- Пропорциональность – использование мер защиты в соответствии с уровнем риска и масштабом возможного ущерба, чтобы избежать чрезмерных затрат.

- Непрерывность – регулярное обновление и адаптация мер безопасности в связи с изменениями в инфраструктуре, угрозах или бизнес-процессах.

- Комплексный подход – объединение и согласование технических, административных и организационных мер для достижения максимальной эффективности.

3.2 Риски классифицируются по уровням критичности:

- Высокий риск – требует немедленного принятия мер по снижению угроз.

- Средний риск – рекомендуется планирование мероприятий по снижению угроз в кратчайшие сроки.

- Низкий риск – допускается текущий мониторинг без принятия срочных мер.

4 План обработки угроз (рисков) ИБ

4.1 Обработка угроз и рисков ИБ включает следующие этапы:

- Выявление угроз (рисков) ИБ – идентификация всех возможных угроз и рисков для информационной безопасности университета.

- Выбор мер обработки угроз (рисков) ИБ – для работы с рисками осуществляется с учётом их уровня критичности и возможных последствий.

4.2 Основные направления обработки включают:

- Уменьшение угроз (рисков) ИБ – снижение уровня риска за счёт внедрения мер и средств контроля, таких как системы защиты информации, мониторинг активности и регулярные проверки инфраструктуры.

- Сохранение угроз (рисков) ИБ – сознательное решение сохранить риск, если он не представляет значительной угрозы, и отказ от дополнительных действий.

- Избежание угроз (рисков) ИБ – отказ от деятельности или условий, которые вызывают конкретный риск (например, изменение процессов, инфраструктуры или поставщиков).

- Передача угроз (рисков) ИБ – делегирование риска сторонним организациям, которые обладают ресурсами и экспертизой для его управления (например, страхование или аутсорсинг).

4.3 Основные принципы работы с рисками

Обработка рисков основывается на:

- Приоритетности – фокус на критически важных активах и угрозах;
- Пропорциональности – соответствие затрат на защиту уровню риска;
- Непрерывности – регулярный пересмотр и обновление стратегий;

- Комплексности – использование технических, организационных и административных мер.

4.4 Для снижения рисков применяются следующие группы мероприятий:

- Технические меры – разработка и внедрение решений для защиты активов, таких как системы обнаружения вторжений, резервное копирование, шифрование данных и установка межсетевых экранов.

- Организационные меры – реализация политик информационной безопасности, разработка инструкций для сотрудников и организация регулярного обучения по вопросам безопасности.

- Административные меры – выполнение аудитов, создание систем отчетности и мониторинг активности пользователей для выявления отклонений от нормального поведения.

4.5 Для выполнения плана обработки рисков требуются:

- Серверное и сетевое оборудование – обеспечение стабильной и безопасной работы информационных систем.

- Средства резервного копирования – защита данных от потерь и восстановление в случае инцидентов.

- Техническая поддержка – обеспечение доступности экспертов и ресурсов для оперативного реагирования на угрозы.

4.6 При обнаружении угроз и рисков информационной безопасности в сегменте сети или в информационном ресурсе, необходимо:

- 1) Зафиксировать событие в журнале регистрации внештатных ситуаций;

- 3) В зависимости от характера и категории события ИБ поставить в известность руководство об инциденте;

- 4) При необходимости ограничить доступ к затронутым объектам информатизации, связанным с инцидентом;

- 5) Провести сбор данных и анализ инцидента, при этом обеспечить сохранность всех первоначальных доказательств;

- 6) Ответственным системным администраторам и сотрудникам в рамках их компетенции осуществить действия по устранению последствий инцидента ИБ;

- 7) Подготовить отчет по инциденту и внести соответствующую запись в журнал регистрации событий ИБ.

4.7 Распределение обязанностей между участниками процесса обработки рисков:

- Руководители подразделений – определение и контроль над критически важными активами, а также участие в принятии решений по снижению рисков.

- Системные администраторы – реализация мер по предотвращению и минимизации угроз.

- Ответственные сотрудники – выполнение мероприятий по снижению рисков, предоставление отчетов и участие в устранении инцидентов.

5 Мониторинг выполнения плана

5.1 Для оценки успешности выполнения плана используются следующие показатели:

- Количество устраненных уязвимостей: оценка устранённых технических и организационных недостатков.
- Снижение числа инцидентов: измерение частоты и серьёзности инцидентов информационной безопасности.
- Скорость реагирования: оценка временных затрат на обработку выявленных угроз.

5.2 Корректировка плана проводится в следующих случаях:

- Изменения в структуре информационных систем или бизнес-процессах.
- Обнаружение новых угроз, требующих оперативного реагирования.
- Рекомендации, полученные по результатам аудитов или внешних проверок.

6 Ответственность

6.1 Ответственными за выполнения плана обработки угроз и рисков назначаются следующие должностные лица:

- Офицер информационной безопасности – осуществляет общий контроль за соблюдением мер информационной безопасности, включая регулярный аудит выполнения требований и актуализацию нормативной базы;
- Руководитель управления ИТ – координирует действия подразделений и сотрудников в части реализации задач, предусмотренных настоящим Каталогом, включая контроль за соблюдением сроков и полнотой выполнения работ;
- Системные администраторы – обеспечивают техническую реализацию мероприятий по защите информации, включая настройку оборудования, администрирование систем и устранение технических уязвимостей.

ЛИСТ ОЗНАКОМЛЕНИЯ

[illegible]

Алматы, 2025